

Wapiti Vulnerability Report Findings

Target: Google Gruyere

Link Scanned: <https://google-gruyere.appspot.com/485610654773785615316672128112596597041/>

Date: 29th October 2025

Introduction

Wapiti is a small black box vulnerability scanner which was used in this lab to ethically analyse an intentionally vulnerable web application for security testing.

Summary of Findings

Summary of Findings	Quantity
Stored Cross-site Scripting	9 Critical
Reflected cross site scripting	1 High
Missing HTTP Only Cookie Flag	1 high
Missing Secure cookie flag	1 high
Missing content security policy	1 medium
Missing clickjacking protection	1 medium
Missing HTTP Strict Transport Security	1 medium
Missing X-Content Type Options	1 Medium

From these findings we can draw that stored XSS vulnerability was the largest risk.

Highest Risk Issues

Stored Cross-Site Scripting

Risk Level: Critical

Affected Areas: /saveprofile, /login, /newaccount.gtl, /snippests.gtl

Description

User input is not sanitized meaning that an attacker is able to inject malicious code onto the server, and since the script executes every time the page loads, it can affect all users.

Impact:

- Account takeover
- Credential theft
- Execution of arbitrary actions as victims

Remediation

- Sanitise user inputs
- Encode special characters
- Implement CSP

Reflected Cross-Site Scripting

Risk Level: High

Affected Areas: /snippests.gtl?uid=

Description

Unsensitised parameters are reflected into the webpage and allows for malicious scripts to be executed when the victim clicks on the script.

Impact:

- Credential theft
- Phishing and redirection

Remediation

Same as stored XSS but including URL parameter handling

Cookies Security Issues

Risk Level: High

Description: When scanned, it showed us that the attributes does not have HTTP only and secure attributes too cookies, therefore this allows for an attacker to steal a user's session. HTTP only presents client-side scripts and secure flag ensures that cookies are only transmitted across HTTPS connections.

1. **Missing HttpOnly – Impact:** Cookies accessible via JavaScript and can be stolen by XSS
2. **Missing Secure Flag – Impact:** Allows for cookies to be transmitted over unencrypted channels

Remediation

Add HttpOnly to the cookie when it is created and add a secure flag too the cookie so ensure that it is only being sent over by HTTPS.

Conclusion

In conclusion, the use of this application proved to be very useful in scanning website vulnerabilities, and I can most definitely see a scenario in the future were having experience utilizing this application would come in handy. Alongside this, the scan revealed high-risk vulnerability which is very useful for website developers when looking at how to secure their website application. Knowing that these vulnerabilities exist also provides an opportunity to address them.